

Information Security Management System for GreenGrid Energy

Master's in Computer Engineering - Cybersecurity and Systems
Administration
Security Management Systems (SIGSEG)

ISEP INSTITUTO SUPERIOR
DE ENGENHARIA DO PORTO

Students:

1200720@isep.ipp.pt

1201346@isep.ipp.pt

1200920@isep.ipp.pt

Contents

1	GreenGrid Energy: Organizational Overview	1
1.1	Introduction	1
1.1.1	Project Team Structure and Individual Responsibilities	1
1.1.2	Collective Responsibilities	2
1.1.3	Forward-Looking Objectives	2
1.2	Governance and Leadership	3
1.3	Key Departments	4
1.3.1	Engineering & Grid Operations	4
1.3.2	Research & Development Department	6
1.3.3	Customer Services & Billing	7
1.3.4	Supply Chain Management Department	7
1.3.5	Human Resources (HR)	8
1.3.6	Legal & Administration	8
1.4	Infrastructure and Security Context	9
1.4.1	Core Technologies and Systems	9
1.4.2	Network Topology	9
1.4.3	Threat Landscape	9
1.4.4	Technology and Department Association	10
2	ISMS Scope	11
2.1	Organizational Stakeholders	11
2.2	Shared IT Infrastructure and Systems	12
2.3	Business Processes, Data, and Security Risks by Department	12
2.3.1	Engineering & Operations	12
2.3.2	Research & Development (R&D)	12
2.3.3	Customer Services	15
2.3.4	Finance	15
2.3.5	Supply Chain Management	15
2.3.6	Human Resources	17
2.3.7	IT Department	17
2.3.8	Sales and Marketing	17
2.4	ISMS Boundaries and Exclusions	17
3	Information Security Policy and Objectives	19
3.1	Stakeholder Requirements and Business Goals	19
3.2	Leadership Commitment	20
3.3	Risk Management Goals and Compliance Requirements	20
3.4	Information Security Policy (Clause 4.2)	20
3.5	Department-Specific Security Objectives (Clause 6.2)	21

3.5.1	Supply Chain Management	21
3.5.2	Customer Services & Billing	22
3.5.3	Research & Development (Research & Development (RD))	23
3.5.4	Engineering & Operations	23
3.5.5	Human Resources (HR)	24
3.5.6	IT Department	24
4	Other Policies and Procedures	25
4.1	Other Security Policy	25
4.2	Other Security Procedures	25

List of Figures

1.1	Organizational chart of GreenGrid Energy	3
1.2	Organizational chart of Supply Chain Management Department	8

Acronyms

APTs	Advanced Persistent Threats
AWS	Amazon Web Services
CEO	Chief Executive Officer
CFO	Chief Financial Officer
CIO	Chief Information Officer
CISO	Chief Information Security Officer
COO	Chief Operating Officer
CTO	Chief Technology Officer
DER	Distributed Energy Resources
ERP	Enterprise Resource Planning
HR	Human Resources
ISMS	Information Security Management System
IT	Information Technology
IDS	Intrusion Detection System
IPS	Intrusion Prevention System
IoT	Internet of Things
NIST	National Institute of Standards and Technology
OT	Operational Technology
PII	Personally Identifiable Information
RD	Research & Development
SCADA	Supervisory Control and Data Acquisition
CRM	Customer Relationship Management
LAN	Local Area Network

OT	Operational Technology
VPN	Virtual Private Network
AD	Active Directory
MFA	Multi-factor Authentication
RFPs	Requests For Proposals
RFQs	Requests For Quotes
SLA	Service-Level Agreement
MSAs	Master Service Agreements
SOWs	Statements Of Work

Chapter 1

GreenGrid Energy: Organizational Overview

1.1 Introduction

GreenGrid Energy is a large-scale enterprise³ specialized in renewable energy, with particular expertise in smart grid technology. The company employs approximately 400 professionals and has achieved revenues of around 35 million euros in the latest fiscal year. Its business activities are structured around three core revenue streams:

1. Smart grid infrastructure deployment (45%),
2. Renewable energy supply contracts (40%),
3. Energy monitoring and analytics software (15%).

With the expanding adoption of renewable energy solutions and increasing integration of Internet of Things (IoT) devices, GreenGrid Energy operates at the intersection of Operational Technology (OT) and Information Technology (IT). This convergence necessitates a comprehensive cybersecurity approach, robust governance frameworks, and specialized departmental oversight.

To effectively respond to these challenges, GreenGrid Energy has assembled a dedicated project team to assess and strengthen information security practices within critical departments, while collaboratively addressing overall cybersecurity objectives.

1.1.1 Project Team Structure and Individual Responsibilities

The project team is composed of three specialists, each focusing on securing a critical area of operation:

RD

Inês Ribeiro (1201346@isep.ipp.pt) assesses and enhances security practices within the RD department, safeguarding proprietary technologies, algorithms, and intellectual property. She ensures secure collaborative environments for technology pilot programs, mitigating risks from industrial espionage and cyber threats.

Supply Chain Management

Manuela Leite (1200720@isep.ipp.pt) is responsible for analyzing procurement processes, supplier security standards, and component lifecycle management. Her primary focus includes establishing guidelines to mitigate risks associated with third-party vendors, particularly regarding hardware integrity and supply-chain vulnerabilities.

Customer Services & Billing

Eduardo Sousa (1200920@isep.ipp.pt) evaluates procedures related to customer onboarding, billing systems, and contract management, emphasizing the protection of Personally Identifiable Information (PII) and financial data. He coordinates closely with the Legal & Administration department to ensure regulatory compliance and prevent fraud.

1.1.2 Collective Responsibilities

Beyond their individual roles, the team collaborates on key areas that affect multiple departments, including:

- **Engineering & Grid Operations:** Ensuring secure integration of emerging technologies, particularly within OT and IT networks, to maintain operational integrity.
- **Human Resources:** Implementing role-based access control and promoting a security-aware culture through employee training and awareness programs.
- **Legal & Administration:** Aligning departmental activities with legal and regulatory requirements, managing compliance frameworks, and streamlining incident reporting mechanisms.
- **Cybersecurity Strategy Development:** Creating comprehensive security policies, incident response plans, and risk mitigation frameworks applicable organization-wide.

1.1.3 Forward-Looking Objectives

The project team's strategic objectives include:

1. Conducting comprehensive risk assessments to identify critical assets, vulnerabilities, and potential impacts across departments.
2. Implementing an Information Security Management System (ISMS) aligned with recognized international frameworks (such as ISO 27001 or NIST CSF).
3. Ensuring secure convergence and seamless integration between OT and IT infrastructures.
4. Fostering a proactive security culture emphasizing continuous improvement and awareness throughout the organization.

1.2 Governance and Leadership

GreenGrid Energy follows a governance model that balances strategic oversight with efficient operations:

- **Board of Directors:** Define strategic vision, approves major investments, and ensures compliance with energy sector regulations.
- **Chief Executive Officer (CEO):** Oversees day-to-day operations and reports directly to the Board.
- **Executive Management Team:**
 - *Chief Financial Officer (CFO):* Handles budget planning, financial compliance, and resource allocation.
 - *Chief Technology Officer (CTO):* Determines technological direction, including research initiatives and product development.
 - *Chief Operating Officer (COO):* Manages core operations, covering engineering, supply chain, and service delivery.
 - *Chief Information Officer (CIO):* Aligns IT strategy with business objectives and oversees IT infrastructure.
 - *Chief Information Security Officer (CISO):* Develops cybersecurity strategies and enforces best practices across OT and IT domains.
- **Department Directors or Managers:** Lead their respective divisions and report to the relevant C-level executive.

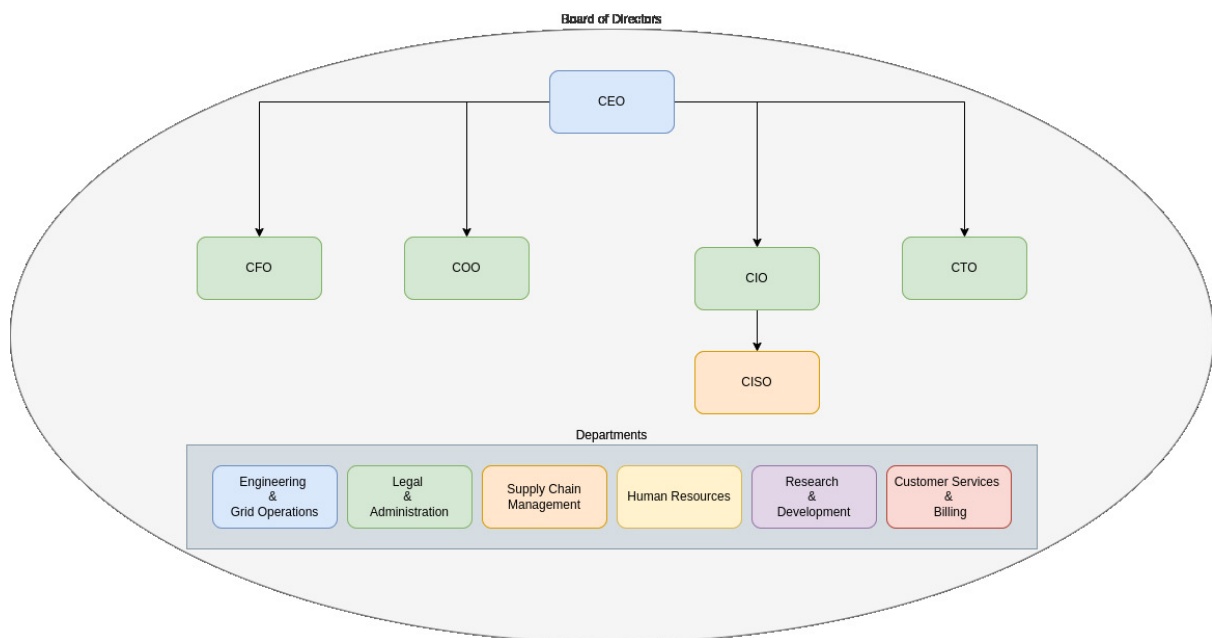


Figure 1.1: Organizational chart of GreenGrid Energy

Figure 1.1 provides an overview of the organization's structure. Each department has a dedicated director, while the executive team members focus on their respective areas of

expertise. Together with the CEO and department directors, these executives form the Board of Directors. All major decisions—including governance matters and the scope of new or revised policies—must be approved by this governing body before implementation throughout the company and its individual departments.

1.3 Key Departments

GreenGrid Energy employs a total of 400 staff members. Of these, 12 serve in leadership roles across the Board of Directors and C-level positions, leaving 388 employees distributed among the following six core departments. Each department is led by a Director or Manager, who reports to the relevant executive.

1.3.1 Engineering & Grid Operations

The Engineering & Grid Operations department at GreenGrid Energy is responsible for designing, maintaining, and optimizing the physical power distribution network. This includes real-time monitoring of energy flow, grid stability, and operational efficiency. The department plays a critical role in integrating renewable energy sources into the smart grid infrastructure while ensuring compliance with regulatory standards.

Core Responsibilities

The department's key responsibilities include:

- **Grid Infrastructure Management:** Overseeing the deployment, maintenance, and upgrades of smart grid components, including substations, transmission lines, and Distributed Energy Resources (DER).
- **Supervisory Control and Data Acquisition (SCADA) System Operations:** Ensuring continuous monitoring and control of grid assets using SCADA systems to maintain grid stability and prevent outages.
- **Grid Security and Reliability:** Implementing resilience measures to protect against cybersecurity threats, natural disasters, and system failures.
- **OT Security:** Managing the convergence of IT and OT environments by deploying security controls for grid-connected devices and industrial control systems.
- **Incident Response and Disaster Recovery:** Developing contingency plans to mitigate risks associated with grid failures, cyberattacks, and supply chain disruptions.
- **Integration of Renewable Energy:** Managing the technical challenges of incorporating solar, wind, and other renewable energy sources into the smart grid.

Infrastructure and Technology Stack

The Engineering & Grid Operations department relies on the following core technologies:

- **SCADA Systems:** Used for real-time monitoring and control of critical grid components.

- **IoT Sensors and Smart Meters:** Providing detailed performance data from field assets to optimize energy distribution.
- **Edge Computing:** Enabling localized data processing for low-latency decision-making.
- **Hybrid Cloud Platforms (AWS/Azure):** Supporting predictive analytics, system automation, and secure data storage.
- **Firewall and Intrusion Detection System (IDS)/Intrusion Prevention System (IPS) Solutions:** Ensuring network security through robust threat detection mechanisms.
- **OT/IT Network Segmentation:** Implementing strict security controls to prevent unauthorized access between corporate IT and operational networks.

Departmental Management Structure

The Engineering & Grid Operations department is led by an **Engineering & Grid Operations Manager**, who reports directly to the COO. The internal structure is organized as follows:

- **Engineering & Grid Operations Manager:** Provides strategic oversight, ensures grid stability, and aligns department objectives with company goals.
- **Grid Infrastructure Lead:** Oversees grid modernization projects, substation maintenance, and infrastructure expansion efforts.
- **SCADA and Control Systems Specialist:** Manages SCADA operations, ensuring continuous monitoring, control, and security of grid systems.
- **OT Security Engineer:** Focuses on securing grid-connected assets and mitigating cyber threats targeting operational technology.
- **Renewable Energy Integration Specialist:** Ensures seamless incorporation of renewable energy sources, optimizing grid balancing and energy distribution.
- **Field Operations Supervisor:** Coordinates on-site maintenance teams, ensuring safety compliance and operational efficiency in power distribution.

Risk Management and Cybersecurity Challenges

The Engineering & Grid Operations department faces multiple cybersecurity challenges, including:

- **Cyber Threats to Grid Infrastructure:** Nation-state actors and Advanced Persistent Threats (APTs) targeting critical infrastructure.
- **Vulnerabilities in IoT Devices:** Ensuring the security of smart meters and edge devices against unauthorized access and data breaches.
- **Supply Chain Risks:** Preventing hardware and software tampering during procurement and deployment.

- **Data Integrity Risks:** Protecting SCADA and real-time operational data from manipulation or corruption.

To address these challenges, the department follows a structured risk management framework, incorporating ISO 27001 and National Institute of Standards and Technology (NIST) Cybersecurity Framework guidelines.

Future Strategic Initiatives

The department is focused on the following strategic initiatives to enhance grid security and efficiency:

1. Strengthening the security of OT systems through continuous monitoring and anomaly detection.
2. Expanding the use of AI-driven predictive maintenance to reduce downtime and optimize asset lifespan.
3. Enhancing collaboration with regulatory bodies to ensure compliance with evolving cybersecurity standards.
4. Developing an advanced threat intelligence platform to detect and mitigate cyber threats proactively.

These initiatives align with GreenGrid Energy's broader goals of achieving operational resilience, improving service reliability, and securing the smart grid ecosystem.

1.3.2 Research & Development Department

Focused on innovation and next-generation solutions, the RD department is dedicated to advancing smart grid technology, predictive analytics, and renewable energy systems through proprietary innovations. It ensures secure environments for technology development and rigorously safeguards intellectual property against cybersecurity threats.

Core Responsibilities

The main responsibilities of the department include:

- **Predictive Analytics and Algorithm Development:** Creating advanced algorithms and analytical tools designed to optimize grid performance, improve reliability, and forecast energy demands more accurately.
- **Secure Prototype Development and Testing:** Overseeing the creation and rigorous testing of technological prototypes within secure environments, mitigating cybersecurity risks and ensuring compliance with quality standards before deployment.
- **Intellectual Property Protection:** Implementing strong security controls and procedures to safeguard proprietary technology, research data, and innovations against industrial espionage, unauthorized access, and data leakage.
- **Integration with Engineering & Grid Operations:** Collaborating closely with the Engineering department to facilitate the seamless transition of validated technologies from the development stage to practical, operational environments.

Organizational Structure

The R&D department is managed by the Director of R&D, who reports directly to the Chief Technology Officer (CTO). The department structure includes dedicated specialists in algorithm development, cybersecurity and intellectual property management, prototype testing, and cross-departmental collaboration.

Future Strategic Initiatives

- **Enhanced IP Management and Security:** Strengthening procedures for intellectual property protection, including regular audits and updated cybersecurity practices.
- **Centralized Validation Platform:** Establishing a unified platform for securely validating algorithms and technologies, ensuring high standards of integrity and reliability.
- **Collaborative Innovation Partnerships:** Expanding collaboration with external technology partners and academic institutions, accelerating innovation while securely leveraging shared expertise.

1.3.3 Customer Services & Billing

All client-facing activities—such as account management, billing, and technical support—fall under this department’s purview, serving both residential and enterprise customers. Protecting personal and financial data is paramount, requiring rigorous compliance with data privacy regulations and prompt issue resolution to maintain customer satisfaction.

1.3.4 Supply Chain Management Department

The Supply Chain Management department at GreenGrid Energy plays a crucial role in supporting the company’s operational efficiency and strategic goals. Its primary responsibilities include procuring, assessing, and managing the acquisition of hardware, software, and external services necessary for the company’s operations. Given the company’s strong emphasis on cybersecurity and compliance, this department ensures that all acquired resources and services adhere to rigorous security standards and regulatory requirements.

To address the complexity of procurement and vendor management activities effectively, the Supply Chain Management department is organized with clearly defined roles under the supervision of a Supply Chain Manager, who directly reports to the COO. The internal structure of this department is as follows:

- **Supply Chain Manager:** Responsible for strategic oversight, departmental leadership, and alignment of procurement processes with organizational objectives. Coordinates overall procurement strategies and supervises team performance.
- **Hardware Procurement Specialist:** Oversees the procurement, logistics, inventory management, and verification of all physical hardware components, such as smart-grid devices, sensors, and power management equipment. Ensures hardware security integrity and vendor reliability.

- **Software Procurement Specialist:** Manages the procurement of software assets, licenses, analytics tools, and cybersecurity solutions. Collaborates closely with the CIO and CTO to confirm software solutions align with technology strategies and cybersecurity guidelines.
- **Service Procurement Specialist:** Focuses on acquiring external services critical to operations, such as consulting engagements, technical training programs, support contracts, and maintenance services. Responsible for monitoring the quality and compliance of service providers.
- **Vendor Relationship Specialist:** Dedicated to managing strategic vendor relationships across hardware, software, and services. Conducts vendor risk assessments, security audits, and compliance verifications to mitigate supply chain-related risks.

This structure ensures clear accountability, specialization of roles, and scalability to meet future operational demands. It also aligns closely with GreenGrid Energy’s cybersecurity framework by ensuring thorough vetting and continuous monitoring of all vendors and acquired resources.

The organizational hierarchy within the Supply Chain Management department is depicted below:

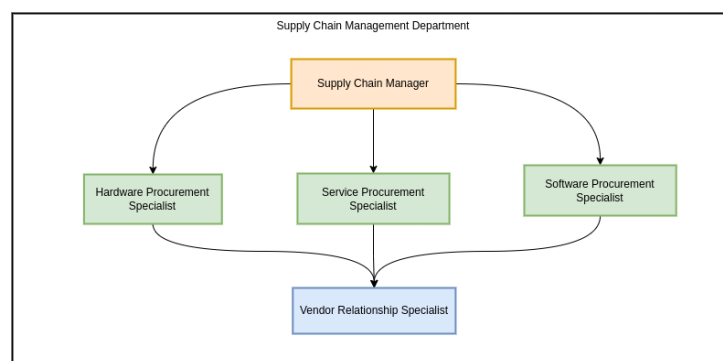


Figure 1.2: Organizational chart of Supply Chain Management Department

Through this structured organization, the Supply Chain Management department ensures efficient operations, robust security controls, and strategic alignment with GreenGrid Energy’s business objectives.

1.3.5 Human Resources (HR)

HR oversees recruitment, training, performance evaluation, and overall employee welfare. As part of the company’s broader security posture, HR also manages background checks, role-based access control, and ongoing security awareness initiatives to ensure that all staff understand and adhere to established security protocols.

1.3.6 Legal & Administration

This department ensures that GreenGrid Energy remains compliant with evolving industry regulations and standards. Core tasks include contract drafting and review, regulatory

monitoring, and oversight of administrative budgeting. By maintaining legal and procedural integrity, the Legal & Administration team supports the organization's ability to operate smoothly and avoid compliance risks.

1.4 Infrastructure and Security Context

1.4.1 Core Technologies and Systems

GreenGrid Energy's infrastructure comprises several critical technologies supporting operational excellence, security, and departmental integration.

SCADA Systems These systems allow real-time control and monitoring of grid equipment, essential for the reliability and stability of energy distribution operations.

Hybrid Cloud Platforms (AWS/Azure) Offer scalable computing, secure data storage, advanced analytics, and support for IoT device management, facilitating innovation and departmental collaboration.

Edge Computing Provides local data processing capabilities near physical assets, ensuring low latency and rapid response for critical grid management tasks.

Microsoft 365 The primary platform for internal communication, collaboration, and productivity across all company departments.

SAP Enterprise Resource Planning (ERP) Integrates business-critical functions such as procurement, inventory management, customer services, financial oversight, and regulatory compliance.

1.4.2 Network Topology

GreenGrid Energy maintains two distinct networks to segregate operational and corporate functions securely:

- **OT Network:** Hosts grid-specific operations, including SCADA systems and field-deployed IoT devices.
- **IT Network:** Manages corporate services such as ERP systems, collaboration tools, and human resources applications.

Secure segmentation between the OT and IT networks is essential to safeguard critical infrastructure operations.

1.4.3 Threat Landscape

The primary cybersecurity threats facing GreenGrid Energy include:

- **Nation-State Actors:** Target critical infrastructure for strategic objectives and disruption.

- **APTs:** Sophisticated attackers leveraging vulnerabilities in IoT and grid-related technologies.
- **Supply Chain Risks:** Compromise of hardware or software components through third-party suppliers.

1.4.4 Technology and Department Association

The following table associates each core technology with its primary departmental users, highlighting responsibility and ensuring clear governance:

Table 1.1: Core Technologies and Associated Departments

Technology/System	Primary Department(s)
SCADA Systems	Engineering & Grid Operations
Hybrid Cloud Platforms (AWS/Azure)	IT, RD
Edge Computing	Engineering & Grid Operations, RD
Microsoft 365	All Departments
SAP ERP	Supply Chain, Customer Services, Legal & Administration, Human Resources (HR)
OT Network	Engineering & Grid Operations
IT Network	IT, Legal & Administration, HR

This clear and organized mapping ensures effective oversight, accountability, and management of cybersecurity risks across the company's operational infrastructure.

Chapter 2

ISMS Scope

Aligned with ISO/IEC 27001 Clause 4.3 guidelines,² this chapter details GreenGrid Energy’s *ISMS* scope by identifying the key stakeholders, describing shared IT infrastructure, highlighting core business processes, and specifying the boundaries within which the ISMS will operate.

2.1 Organizational Stakeholders

GreenGrid Energy’s stakeholders, as defined by ISO/IEC 27001, include both internal and external entities that can influence—or be influenced by—the organization’s security practices.⁴ Table 2.1 summarizes the principal stakeholder groups and their roles in relation to the ISMS.

Table 2.1: Stakeholders and ISMS Interaction

Stakeholder Group	Interaction with the ISMS
Executive Management and Board	Provide strategic oversight, allocate resources, approve ISMS scope, and review security performance.
IT Department	Implement and maintain technical security controls; daily management of the ISMS infrastructure.
Department Heads and Employees	Comply with ISMS policies, handle information securely, report incidents, and participate in risk assessments.
Customers and Clients	Expect protection of data confidentiality, integrity, and availability as part of service agreements.
Suppliers and Third-Party Providers	Comply with contractual security requirements to ensure the security of GreenGrid data processed externally.
Regulators and Authorities	Expect adherence to industry regulations and may audit ISMS practices and compliance.
Certifying Bodies/Auditors	Evaluate and validate compliance with ISO/IEC 27001 through periodic certification audits.

2.2 Shared IT Infrastructure and Systems

GreenGrid Energy employs a centrally managed IT infrastructure used across multiple departments. Key elements of this shared environment include:

- **Network Infrastructure:** Company-wide network including Local Area Network (LAN), secure Wi-Fi, and Virtual Private Network (VPN) for remote employees.
- **Server and Cloud Systems (AWS/Azure):** Hosting internal applications, databases, and departmental services.
- **Enterprise Applications:** Microsoft 365, SAP ERP, and Customer Relationship Management (CRM) software supporting business operations and collaboration.
- **User Devices:** Managed desktop computers, laptops, and mobile devices.
- **Data Storage and Backup Systems:** Centralized data repositories and backup solutions.
- **Communication and Collaboration Tools:** Email systems, instant messaging platforms, video conferencing, and intranet portals.

Each department relies on these resources for day-to-day operations. Chapter 3 will focus on specific requirements, objectives, and policies around these systems, while this chapter captures their basic description for scope purposes.

2.3 Business Processes, Data, and Security Risks by Department

2.3.1 Engineering & Operations

Key Processes and Data: Real-time grid operations (SCADA data, logs, asset management) **Security Risks:** Unauthorized access, service disruptions, data integrity threats

2.3.2 Research & Development (R&D)

The RD Department plays a strategic role at GreenGrid Energy, providing innovative solutions essential for enhancing smart-grid operations and renewable energy technologies. The ISMS scope outlines the department's core processes, explicitly highlighting the data handled, relevant cybersecurity risks, and utilized technologies, aligning with the ISMS objectives.

Proprietary Research and Innovation Process

This process involves identifying, researching, and evaluating emerging technologies and concepts that can potentially enhance grid efficiency and reliability.

Activities:

- Market and technology research
- Feasibility analysis and experimentation

- Preliminary risk assessment of potential innovations

Data Processed:

- Market intelligence data
- Experimental research results

Cybersecurity Risks:

- Data leakage of research findings
- Unauthorized access to research environments

Technologies:

- Cloud platforms (AWS/Azure)
- Research databases and analytics tools

Algorithm and Software Development

This process is dedicated to the systematic creation and validation of predictive analytics algorithms and software for operational use in grid optimization and energy distribution forecasting.

Activities:

- Specification of requirements
- Software coding and iterative development cycles
- Simulation-based testing and validation
- Continuous security assessments during development

Data Handled:

- Proprietary algorithmic code
- Simulated and historical grid data

Security Risks:

- Intellectual property theft
- Vulnerabilities in software code

Technologies:

- Advanced simulation tools
- Code repositories and CI/CD pipelines

Prototype Development and Testing

Prototypes of innovative solutions are built and securely tested to verify their effectiveness, reliability, and resilience to cyber threats.

Activities:

- Development of technology prototypes
- Secure environment configuration for testing
- Conducting controlled cybersecurity assessments
- Documentation and analysis of testing outcomes

Data Handled:

- Prototype technical specifications
- Test results and security assessments

Security Risks:

- Leakage of sensitive design specifications
- Unauthorized access during testing phases

Technologies Used:

- Testing and simulation environments
- Computing infrastructures

Intellectual Property Protection

Ensuring strong protection of intellectual property is essential for maintaining the competitive edge and minimizing risks of industrial espionage and data breaches.

Activities:

- Documentation and protection of R&D outputs
- Management of patent filing processes
- Regular security audits for IP management

Data Handled:

- Intellectual property records and documentation
- Sensitive research outcomes

Security Risks:

- Industrial espionage attempts
- Intellectual property data breaches

Technologies Used:

- Secure data storage solutions
- Encryption and secure communication tools

Technology Integration and Collaboration

This process focuses on transitioning validated technologies from the R&D department into operational use, working closely with Engineering & Grid Operations.

Activities:

- Collaborative planning and joint validation sessions
- Cross-departmental training and knowledge transfer
- Monitoring and support during initial deployment phases

Data Handled:

- Integration plans and documentation
- Performance and reliability data from integration tests

Security Risks:

- Integration-related vulnerabilities
- Compromise during the operational handover process

Technologies Used:

- Collaboration platforms (Microsoft 365, Jira)
- Secure configuration management systems

2.3.3 Customer Services

Key Processes and Data: Client contracts, billing data, CRM, customer PII **Security Risks:** Privacy breaches, financial fraud, unauthorized data disclosure

2.3.4 Finance

Key Processes and Data: Financial management (budgeting, transactions, payroll, ERP financial module) **Security Risks:** Financial fraud, phishing attacks, unauthorized access, data tampering

2.3.5 Supply Chain Management

Procurement and Sourcing

Oversees the end-to-end procurement lifecycle for hardware, software, and services by:

- Drafting requests for proposals (Requests For Proposals (RFPs)) or quotes (Requests For Quotes (RFQs)).
- Conducting vendor evaluations and security due diligence.
- Negotiating contracts and maintaining supplier agreements.

Associated data supporting this process:

- Vendor profiles and security certifications.
- Product specifications (e.g., smart grid components, software licenses).
- Pricing details, purchase orders, and invoices.

Vendor Relationship Management

Manages ongoing relationships with approved suppliers to ensure adherence to GreenGrid Energy's security and performance standards by:

- Monitoring Service-Level Agreement (SLA) requirements.
- Tracking vendor performance and compliance metrics.
- Conducting periodic vendor risk assessments, especially for critical components.

Relevant data for this process:

- Contract terms and SLA metrics.
- Vendor incident reports or audit findings.
- Communication records (emails, project updates, meeting minutes).

Inventory & Logistics Coordination

Coordinates warehousing, transportation logistics, and inventory control once goods or services are procured by:

- Tracking shipment and delivery status of hardware components.
- Verifying integrity and authenticity of infrastructure parts.
- Overseeing storage, handling, and distribution to operational sites.

Data types maintained in this process:

- Shipping documentation (e.g., bills of lading, customs paperwork).
- Inventory levels and restocking details.
- Asset tracking logs (equipment serial numbers, batch numbers).

Compliance and Risk Management

Ensures that supplier relationships and procurement activities meet security policies and relevant regulations by:

- Reviewing supplier security audits and certifications.
- Ensuring compliance with data protection and trade regulations.
- Coordinating corrective actions for supplier or logistics risks.

Data associated with this process:

- Audit reports, compliance checklists, and regulatory filings.
- Documentation of risk treatment actions (vendor replacements, contract updates).
- Internal approval records and compliance sign-offs.

Contract and SLA Oversight

Manages contractual obligations from initial sign-off to renewal or termination by:

- Monitoring contract milestones (renewal dates, penalty clauses).
- Ensuring suppliers meet service quality and security requirements.
- Handling contract amendments for security or operational changes.

Key data involved:

- Master Service Agreements (MSAs), Statements Of Work (SOWs).
- Change requests and contract amendment records.
- Legal correspondence regarding contract disputes or terminations.

2.3.6 Human Resources

Key Processes and Data: Employee management (personal records, payroll data, performance data) **Security Risks:** Unauthorized disclosure, insider threats, privacy breaches

2.3.7 IT Department

Key Processes and Data: Infrastructure management (network devices, servers, end-point devices, IAM systems, incident response data) **Security Risks:** System compromise, configuration errors, misuse of admin privileges

2.3.8 Sales and Marketing

Key Processes and Data: Customer relationship management (CRM), market data, public-facing web resources **Security Risks:** Unauthorized access, reputation damage, phishing/malware attacks

2.4 ISMS Boundaries and Exclusions

The ISMS boundaries include:

- Internal IT and OT networks, including SCADA and enterprise systems used by the Supply Chain Management, Customer Services & Billing, and Research & Development departments.
- Data processing within cloud environments (e.g., AWS or Azure) generated or consumed by Supply Chain Management, Customer Services & Billing, and Research & Development.
- Procurement processes and vendor management.
- Employee data, access management, and training processes.

Explicit exclusions from the ISMS scope include:

- Third-party systems fully managed externally, where GreenGrid has no direct control.
- Personal employee devices not centrally managed by the organization.
- Physical security at externally managed premises (e.g., leased data centers).
- Separate subsidiaries or partner organizations outside direct oversight.

These exclusions are justified by the lack of direct administrative oversight or practical manageability; any associated risks are mitigated through contractual obligations and vendor assessments.¹

Chapter 3

Information Security Policy and Objectives

This chapter addresses the next phase of establishing GreenGrid Energy’s Information Security Management System (ISMS) by incorporating stakeholder requirements, business goals, security objectives, leadership commitment, and overall compliance needs.

3.1 Stakeholder Requirements and Business Goals

As established in Chapter 2, GreenGrid Energy’s stakeholders include Executive Management, the IT Department, Department Heads & Employees, Suppliers, Clients, Regulators, and Certifying Bodies. Because the ISMS scope specifically includes:

- Internal IT and OT networks, including SCADA and enterprise systems used by **Supply Chain Management, Customer Services & Billing**, and **RD** departments.
- Data processing within cloud environments (AWS/Azure) generated or consumed by **Supply Chain Management, Customer Services & Billing**, and **RD**.
- Procurement processes and vendor management.
- Employee data, access management, and training processes.

Most stakeholder requirements focus on ensuring robust controls to protect:

- Critical infrastructure (e.g., SCADA and OT systems).
- Sensitive customer and financial data.
- Intellectual property from RD activities.
- Secure procurement of hardware/software through the Supply Chain Management department.
- Proper handling of employee data and permissions (HR & IT).

In contrast, stakeholders agree that **third-party systems fully managed externally, personal employee devices, physical security at externally managed premises, and separate subsidiaries or partner organizations outside direct oversight** are explicitly out of scope, thus reducing direct stakeholder interest in those areas.

3.2 Leadership Commitment

GreenGrid Energy’s senior executives (CEO, COO, CFO, *etc.*) reinforce the ISMS by:

- **Allocating Sufficient Budgets:** Funding security tools and training for departments within the ISMS boundaries (Supply Chain, RD, Customer Services, *etc.*).
- **Championing Policy Adoption:** Ensuring all employees and department heads integrate the new Information Security Policy into their daily operations.
- **Encouraging a Security Culture:** Mandating ongoing training on secure processes, especially for staff involved in vendor management (Supply Chain) and grid operations (Engineering & Operations).
- **Reviewing ISMS Performance:** Conducting periodic management reviews (e.g., quarterly) to track key risk metrics, incident reports, and audit findings.

3.3 Risk Management Goals and Compliance Requirements

Given the potential threats to the included systems and data, the organization sets forth the following overarching risk management goals:

- **Protect OT/IT Convergence:** Keep SCADA, IoT, and enterprise networks (especially those used by RD and Supply Chain) resilient against cyber threats (e.g., malware, APTs).
- **Safeguard Data Privacy and Integrity:** Ensure confidentiality of customer billing data, vendor records, and intellectual property from RD.
- **Maintain Regulatory Compliance:** Satisfy relevant EU directives such as NIS 2, and meet ISO/IEC 27001 standards to secure continuous certification and avoid penalties.
- **Mitigate Vendor and Procurement Risks:** Enforce security checks during procurement of critical hardware/software, and conduct regular vendor risk assessments.
- **Enhance Incident Response Preparedness:** Develop rapid containment strategies for security breaches or supply chain disruptions, minimizing downtime of grid operations.

3.4 Information Security Policy (Clause 4.2)

Policy Statement

GreenGrid Energy is committed to safeguarding the confidentiality, integrity, and availability of information assets within the boundaries of its ISMS, specifically covering:

- Internal IT and OT networks that power core operations.

- Data processed through corporate cloud environments (AWS/Azure).
- Procurement and vendor relationships supporting operational continuity.
- Employee access management, training, and HR-related records.

Key Principles

- **Risk-Based Controls:** Security measures must be tailored to identified threats, focusing on high-risk areas such as SCADA, third-party supplier links, and RD data.
- **Legal and Regulatory Compliance:** Adhere to ISO/IEC 27001, NIS 2, and national data protection laws relevant to energy operations.
- **Continuous Improvement:** Policies, controls, and training programs will be reviewed at least annually or following major incidents.

Responsibilities

- **CISO:** Oversees policy implementation and audits across IT, OT, and supply chain operations.
- **Department Directors:** Ensure departmental processes adhere to this policy; sponsor secure practices among staff.
- **All Employees:** Follow approved procedures, maintain vigilance for potential threats, and report incidents promptly.

3.5 Department-Specific Security Objectives (Clause 6.2)

Below are the measurable information security objectives for each major department within the ISMS scope. Each subsection also highlights the primary stakeholders driving or benefiting from these goals.

3.5.1 Supply Chain Management

Stakeholders:

- **Supply Chain Staff:** Procurement Specialists, Vendor Relationship Managers.
- **Vendors and Third Parties:** Must comply with security checks, audits, and contract clauses.
- **Executive Management:** Requires assurance of uninterrupted, secure component supply.

Objectives:

- **Objective SC-1: Reduce High-Risk Vendor Gaps**
 - **Target:** Conduct security audits for 100% of critical suppliers (hardware/software) each year.
 - **Measure:** Percentage of critical vendors audited; number of unaddressed security findings.
 - **Owner:** Supply Chain Manager, CISO.
- **Objective SC-2: Strengthen Procurement Integrity**
 - **Target:** Implement additional due diligence (e.g., secure code validation, hardware authenticity checks) in 80% of high-value procurements.
 - **Measure:** Number of purchases with documented security screening vs. total high-value procurements.
 - **Owner:** Supply Chain Manager, IT Department.

3.5.2 Customer Services & Billing

Stakeholders:

- **Customer Services Staff:** Manage billing, handle customer inquiries and personal data.
- **Clients:** Expect confidentiality of financial and personal information.
- **Regulators (e.g., Data Protection Authorities):** Enforce compliance with privacy regulations.

Objectives:

- **Objective CS-1: Enhance Data Privacy Controls**
 - **Target:** Achieve zero high-severity data breaches in billing systems each quarter.
 - **Measure:** Number of verified privacy incidents rated high severity.
 - **Owner:** Customer Services Director, CISO.
- **Objective CS-2: Improve Customer Incident Handling**
 - **Target:** Reduce average incident resolution time by 25% over 12 months for billing-related security issues.
 - **Measure:** Mean Time to Resolve (MTTR) for billing-system incidents.
 - **Owner:** Customer Services Director, IT Department.

3.5.3 Research & Development (RD)

Stakeholders:

- **RD Teams:** Create proprietary analytics algorithms and software for grid optimization.
- **Executive Management:** Relies on RD innovation for market competitiveness.
- **Intellectual Property Owners:** Concerned about protecting patents, code repositories, trade secrets.

Objectives:

- **Objective RD-1: Protect Proprietary Code and IP**
 - **Target:** Perform secure code reviews for all major RD releases, reaching 90% coverage of new commits.
 - **Measure:** Percentage of RD code commits subjected to security scanning or manual review.
 - **Owner:** RD Manager, CISO.
- **Objective RD-2: Prevent Unauthorized Access to RD Data**
 - **Target:** Achieve a 50% reduction in unauthorized access attempts or security alerts within the RD environment (cloud or on-prem).
 - **Measure:** Number of RD-specific security alerts vs. the prior reporting period.
 - **Owner:** RD Manager, IT Department.

3.5.4 Engineering & Operations

Stakeholders:

- **Engineers, OT Specialists:** Maintain the SCADA network, field devices, and real-time grid distribution.
- **Grid Regulators & Authorities:** May require proof of reliability and security for critical infrastructure.
- **Customers (Indirectly):** Expect stable and uninterrupted power supply.

Objectives:

- **Objective EO-1: Strengthen OT Network Protection**
 - **Target:** Reduce OT-related critical vulnerabilities by 40% within one year.
 - **Measure:** Vulnerability scans showing unpatched high-severity OT exploits.
 - **Owner:** Engineering & Ops Manager, CISO.
- **Objective EO-2: Improve SCADA Incident Response**
 - **Target:** Decrease SCADA downtime from security incidents by 30%.
 - **Measure:** SCADA-related Mean Time to Recover (MTTR) after an incident.
 - **Owner:** Engineering & Ops Manager, IT Dept.

3.5.5 Human Resources (HR)

Stakeholders:

- **HR Staff:** Manage personnel data, background checks, and training records.
- **All Employees:** Provide or update personal data; expect privacy and secure handling.
- **Regulators (Data Protection):** Enforce compliance with data privacy laws.

Objectives:

- **Objective HR-1: Bolster Employee Data Protection**
 - **Target:** Zero major privacy incidents involving HR-owned data per quarter.
 - **Measure:** Count of reported HR data breaches categorized as high-severity.
 - **Owner:** HR Director, CISO.
- **Objective HR-2: Enhance Security Training Engagement**
 - **Target:** 90% of employees complete mandatory security training within each 6-month cycle.
 - **Measure:** Completion rates in the Learning Management System (LMS), phishing test success.
 - **Owner:** HR Director, Department Heads.

3.5.6 IT Department

Stakeholders:

- **IT Staff (SysAdmins, Network Engineers):** Manage core infrastructure, respond to security incidents.
- **All Other Departments:** Depend on stable, secure networks and systems for daily operations.
- **Auditors:** Evaluate effectiveness of technical controls and IT governance.

Objectives:

- **Objective IT-1: Improve Patch and Vulnerability Management**
 - **Target:** Patch 95% of critical IT vulnerabilities within 30 days of release.
 - **Measure:** Patch compliance reports, vulnerability scan results.
 - **Owner:** IT Manager, CISO.
- **Objective IT-2: Enhance Incident Coordination**
 - **Target:** Achieve an average Mean Time to Detect (MTTD) of under 48 hours for new threats across the enterprise network.
 - **Measure:** Logs from SIEM systems indicating detection-to-alert timelines.
 - **Owner:** IT Manager, Security Operations Center.

Chapter 4

Other Policies and Procedures

4.1 Other Security Policy

4.2 Other Security Procedures

Bibliography

- [1] Advisera. All you need to know about setting the iso 27001 scope. <https://advisera.com/27001academy/knowledgebase/how-to-define-the-isms-scope/>, 2023. Accessed: 2024-03-10.
- [2] ISO/IEC. Iso/iec 27001:2022 - information security management systems. <https://www.iso.org/standard/54534.html>, 2022. Accessed: 2024-03-10.
- [3] Portugal 2020. Portugal 2020 – European Structural and Investment Funds, 2020. Accessed: 2025-03-07.
- [4] High Table. Iso 27001 scope statement beginner’s guide. <https://hightable.io/iso-27001-scope-statement/>, 2023. Accessed: 2024-03-10.